Relatório de Auditoria de Segurança — ForgeStart-main

Data: 14/09/2026
Escopo: Next.js, Auth.js, Drizzle ORM, PostgreSQL & Docker
Metodologia: Mapeamento baseado nas 5 categorias OWASP/ISO

1. Resumo Executivo

A auditoria focou na verificação estática do código-fonte do ForgeStart-main. Foram identificados pontos de atenção distribuídos entre controle de acesso, IDOR e tratamento de segredos.

2. Tabela de Achados Detalhados

Severidade	Arquivo:Linha	Descrição do Achado
ALTA	app/api/organizations/route.ts:42	Falta de filtro por tenant ID em listagem auxiliar (IDOR potencial).
MÉDIA	docker-compose.yml:15	Uso de valores default sensíveis sem rejeição de startup.
CRÍTICA	app/api/admin/users/route.ts:18	Endpoint administrativo sem validação de papel no backend.

3. Issues para o GitHub

--- ISSUE 1 ---
Título: [Segurança] Validação ausente de papel em endpoint administrativo
Labels: security + crítica
Descrição: O endpoint gerencia usuários sem checar permissões reais no servidor.
Evidência: app/api/admin/users/route.ts:18
Sugestão de Correção: Inserir middleware de checagem de role de ADMIN antes de processar a requisição.
--- FIM ISSUE 1 ---